

KIIRA MOTORS CORPORATION

HEALTH AND WELLNESS MANAGEMENT SYSTEM

INFORMATION SECURITY REVIEW

Field	Detail
Document name	Information security review
Reference number	KMC.DQHSE.08/26-SP003
Document description	Security assessment of the Health and Wellness Management System covering identity, clinical confidentiality, data protection, audit and the remediation required before user testing
Prepared by	Akanga Andrew, Software Engineering Intern, Department of Quality, Health, Safety and Environment
Issue date	21/08/2026
Version	003
Classification	Confidential, Restricted to KMC ICT, the data protection owner and departmental management

Table of Contents

1 Introduction.....	4
1.1 Purpose.....	4
1.2 Why this system warrants a review.....	4
1.3 Scope.....	4
1.4 Severity scale.....	4
2 Security architecture.....	5
2.1 Identity and session.....	5
2.2 Authorisation.....	5
2.3 Clinical confidentiality.....	5
2.4 Access logging.....	6
2.5 Telemetry minimisation.....	6
2.6 Referral integrity at creation.....	7
2.7 Clinical to metrics boundary.....	7
3 Findings.....	7
3.1 High findings.....	7
3.2 Medium findings.....	8
3.3 Low findings and observations.....	8
3.4 Controls found to be effective.....	9
4 Data protection.....	10
4.1 Obligations.....	10
4.2 Synthetic data in non-production.....	10
4.3 Patient history export and data minimisation.....	10
4.4 A conflict requiring a decision.....	10
5 Remediation.....	11
5.1 Before user testing.....	11
5.2 Before real clinical records.....	11
5.3 Compensating controls during testing.....	12
6 Conclusion.....	12

List of Figures

Figure 2.1: The four layers enforcing clinical access.....	5
--	---

List of Tables

Table 1.1: Finding severity definitions.....	4
Table 2.1: Clinical access controls and their assessment.....	5
Table 3.1: High severity findings.....	7
Table 3.2: Medium severity findings.....	8
Table 3.3: Low severity findings and observations.....	8
Table 4.1: Data protection obligations and position.....	10
Table 5.1: Remediation required before user testing.....	11
Table 5.2: Remediation required before any real clinical record.....	11
Table 6.1: Information security review sign-off.....	12

1 Introduction

1.1 Purpose

This review records the security posture of the Health and Wellness Management System as built, identifies the weaknesses that exist in it, and states what must be closed before the system is used for testing and before it is ever used for real clinical records. It is written to be usable as a working remediation plan rather than as a compliance statement.

1.2 Why this system warrants a review

The system holds data concerning health, which the Data Protection and Privacy Act, 2019 treats as special personal data attracting the highest protection. It holds that data about employees, on behalf of their employer. The risk therefore is not only that an outsider reads a record. It is that a colleague reads one, and that an employee suffers an employment consequence from a medical disclosure.

That shapes the whole assessment. The controls examined most closely are the ones that separate the clinical record from the rest of the organisation, and the ability of the system to say afterwards who read what.

1.3 Scope

The review covers the application as delivered. That is the sign in and session design, the authorisation model, the clinical confidentiality controls, the audit and access logging, secret handling, container construction and the handling of personal data.

The review does not cover the physical security of any hosting site, the security of the KMC network into which the system would be deployed, or the internal security of Keycloak as a product. It is not a penetration test. It is a design and implementation review conducted against the delivered source, schema, configuration and tests.

1.4 Severity scale

Table 1.1: Finding severity definitions

S/N	Severity	Definition	Required response
1	Critical	Allows an unauthorised party to read a clinical record, or to act as an authorised user	Close before any use, including testing
2	High	Materially increases the likelihood of account compromise, or removes the ability to detect misuse	Close before real clinical records are entered
3	Medium	Weakens defence in depth or the ability to investigate	Close within the first release after go live
4	Low	Hardening opportunity with limited practical exposure as deployed	Close when the affected component is next changed
5	Observation	No action strictly required. Recorded to inform later design	No deadline

2 Security architecture

2.1 Identity and session

Authentication is delegated entirely to Keycloak. The application never receives a password, which removes a whole category of risk and means that password policy, lockout, multi factor authentication and later corporate single sign on are configuration rather than code.

The browser holds no token. The gateway completes the sign in exchange, keeps the tokens in server side session state and issues the browser an opaque identifier in a cookie marked HttpOnly, Secure and SameSite. A token readable by any script on the page would be an unacceptable exposure in a system holding health data, and this design removes it.

Sign in uses the authorisation code flow with a proof key, so an intercepted authorisation code cannot be exchanged by another party. Session lifetime is bounded by inactivity rather than by age, which is the appropriate control for shared clinic workstations.

2.2 Authorisation

Every service validates the token independently rather than trusting the gateway to have done so. Within a service, authorisation is checked twice, once in the request handler and once in the service layer. The second check is not redundant. It protects a code path reached from a scheduled job or an internal caller that never passes through a handler.

2.3 Clinical confidentiality

The rule that only the Health and Wellness Officer may retrieve an individual clinical record is enforced in four independent places.

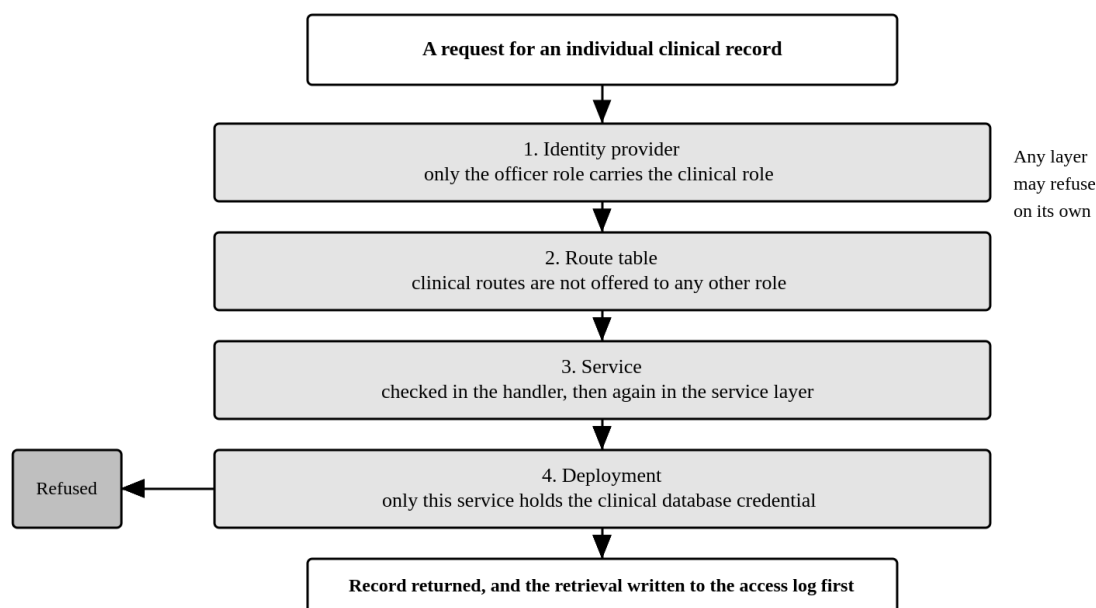


Figure 2.1: The four layers enforcing clinical access

Table 2.1: Clinical access controls and their assessment

S/N	Layer	Control	Assessment
1	Identity provider	Only the officer role carries the clinical role	Effective
2	Route table	Clinical routes are not offered to any other role	Effective, and a courtesy rather than a control
3	Service	Role checked in the handler and again in the service layer	Effective and proved by automated test
4	Deployment	Only the clinical service holds a credential for the clinical database	Effective. Strengthened further by network policy in the cluster manifests

An automated suite asserts every clinical route against every role that is not the officer, and walks the route tree so that a route added without being covered fails the build. The suite runs against an unusable data layer, so a handler that reached data before checking the role would fail rather than pass. This is a genuine control and not a formality.

2.4 Access logging

Ordinary audit practice logs changes. Under the Act the risk to the person arises from unauthorised reading rather than unauthorised writing, so a log that captured only changes would provide no evidence about the harm most likely to occur.

Every retrieval of an individual clinical record is written to `clinical_access_log` before the record is returned. The ordering is deliberate. A log written after the response is a log that is missing precisely when a process fails during the request, which is when somebody will ask what was read. If the log cannot be written the read does not happen.

Searching the registry is logged as a retrieval, with the number of records returned, because a search by name reveals who attends the clinic just as surely as opening one record does.

The table is not append-only against the database role used by the clinical service. The application code defines no update or delete path for it, but the migration contains no GRANT or REVOKE statement preventing that same role from altering or deleting rows. The log also remains inside the clinical database and there is no separate hwms-audit deployable. The fail-before-return behaviour is effective, while stored-log tamper resistance is not implemented.

2.5 Telemetry minimisation

Ordinary request logs record the chi route template rather than the concrete request path. Panic recovery applies the same rule. A request to `/api/clinical/referrals/{id}` is therefore logged as that template, not as an address containing a referral identifier. This prevents patient, visit and referral identifiers from entering ordinary service logs, where clinical access controls and retention do not apply. Query strings and request bodies are not logged.

2.6 Referral integrity at creation

Referral creation accepts patient and visit identifiers from the browser, then derives the patient identity and visit vital signs server side. A database join requires the visit to belong to that patient before the referral is inserted. This protects against a stale browser tab pairing one person's identity with another person's attendance, which would otherwise create a clinically wrong external document without requiring a malicious caller.

2.7 Clinical to metrics boundary

Recommended sick leave crosses from clinical to metrics as four non-clinical fields: referral identifier, feedback version, reporting month and days. It carries no patient identifier, name, diagnosis, treatment or free text. Metrics has no clinical database credential, which makes the data separation structural rather than dependent on a reporting query being written carefully.

A contract test in clinical inspects the outbox column set, and a mirror test in metrics inspects the receiving table. Either test fails the ordinary build if its schema is widened. The transport is an internal HTTP route authenticated by a shared secret, not a scoped OIDC service account. The schema boundary is effective, while caller authentication remains a production weakness at SEC-06 and DEC-034.

3 Findings

Sixteen findings were raised. None is assessed as critical. Six are high, six are medium, two are low and two are observations. Each is stated with what was observed, why it matters operationally, and the specific change that closes it.

3.1 High findings

Table 3.1: High severity findings

S/N	Reference	Finding	Impact	Remediation
1	SEC-01	The Compose environment serves plain HTTP. The k3s ingress proposes TLS, but no provisioned environment or certificate was available to verify	A Compose deployment beyond a laptop would carry credentials and clinical data in clear text, and its session cookie is not secure	Terminate encryption at the UAT ingress, set the secure cookie flag and evidence the certificate before network testing
2	SEC-02	Development credentials are held in the repository, including identity provider client secrets	Anyone with repository access holds the credentials of any environment that used them unchanged	Generate fresh values from a KMC controlled source. Never deploy the repository defaults
3	SEC-03	Multi factor authentication is not enabled for the officer or the manager	A single stolen password grants either clinical access or the ability to create accounts	Enable a second factor in the identity provider for both roles. No application change required
4	SEC-04	The clinical access log is written by the clinical service role, and no database grant prevents that role updating or deleting its rows. There is no	The service that reads clinical data can also alter the evidence of those reads, so the log is not append-only against its own role	Create the separate audit boundary, grant the clinical service insert only, and ship or store the log where that service cannot alter it

S/N	Reference	Finding	Impact	Remediation
		hwms-audit deployable		
5	SEC-05	Downloading a patient history summary creates no distinct audit event. Browser generation reuses data from the earlier detail read, and access_route does not permit export	An ordinary view and creation of a portable clinical file are indistinguishable, so later disclosure cannot be reconstructed from the access record	Permit an export event, write it immediately before generation, and refuse the download if the audit write fails. Resolve DEC-037
6	SEC-06	Clinical authenticates to the internal metrics ingest route with a shared bearer secret	The caller has no scoped service identity, and rotating or attributing one shared credential is weaker than the identity controls used elsewhere	Register a confidential Keycloak client with only the leave-ingest scope and validate its token at metrics before production

3.2 Medium findings

Table 3.2: Medium severity findings

S/N	Reference	Finding	Impact	Remediation
1	SEC-07	Session state is held in the gateway process	A restart signs everybody out. The gateway cannot be scaled, so it is a single point of failure	Move the session store behind the existing interface to a shared store
2	SEC-08	There is no rate limit on the sign-in path	Password guessing is slowed only by the identity provider lockout	Apply a rate limit at the ingress in addition to the lockout
3	SEC-09	Logs and traces are not aggregated	Investigating an incident requires reading each service separately, and log retention is not assured	Add collection to storage held outside the services
4	SEC-10	Amendment of a signed clinical record is not implemented	A correction cannot be made, so pressure will build to reopen a signed record, which would defeat the signature	Build the appended amendment before real records are entered
5	SEC-11	No automated dependency or image vulnerability scanning is configured	A known vulnerability in a dependency would not be noticed	Add scanning to the build once a pipeline exists
6	SEC-12	The k3s clinical database URL requires TLS, but the clinical PostgreSQL StatefulSet configures no server certificate	The clinical service would fail to connect as written. Weakening the URL to make it start would silently remove a required control	ICT supplies the server certificate and PostgreSQL TLS configuration, or approves a different connection policy in writing

3.3 Low findings and observations

Table 3.3: Low severity findings and observations

S/N	Reference	Severity	Finding	Remediation
1	SEC-13	Low	The identity provider administrative console is exposed on the same host as the	Restrict the console to an administrative network

S/N	Reference	Severity	Finding	Remediation
			application	
2	SEC-14	Low	Backups are not yet configured in any environment	Configure nightly encrypted backup, with the clinical backup under a separate key, before real records exist
3	SEC-15	Observation	The interface hides controls a role may not use rather than disabling them	No action. This is deliberate, and is recorded so it is not mistaken for a missing server-side control
4	SEC-16	Observation	DEC-024 remains open and no management role has any route to referral content, including the minimum-disclosure summary	Keep the officer-only posture until the accountable sponsor and Data Protection Officer decide the lawful management route

3.4 Controls found to be effective

The following were examined and assessed as effective. They are recorded because they are the parts of a security design that are difficult to retrofit, and because a review that lists only weaknesses gives a false impression of the whole.

- Delegated authentication, so the application never handles a password.
- Tokens held server side, with the browser holding an opaque identifier only.
- Authorisation checked at two layers within each service, and proved by a suite that blocks the build.
- The clinical database as a separate instance with credentials issued to one service alone.
- Read access logging that fails the read rather than serving a record unlogged.
- Request and panic logs that use route templates rather than concrete paths containing clinical identifiers.
- Referral creation that derives identity and vital signs through a server-side join proving the visit belongs to the patient.
- A four-field clinical to metrics schema boundary, with a contract test on each side and no clinical database credential held by metrics.
- Account administration performed by the service through its own account rather than by replaying the user token.
- Containers built from a minimal base, running as a non root user with a read only filesystem.
- No clinical narrative in any ordinary log line, metric label or trace.

4 Data protection

4.1 Obligations

Data concerning health is special personal data under the Act. The obligations that bear most directly on this system are lawful basis, data minimisation, the ability to report who accessed a person record, retention limits, and the security of processing.

Table 4.1: Data protection obligations and position

S/N	Obligation	Position	Outstanding
1	Lawful basis and privacy notice	Not yet established	Required before real records. Owned by the data protection owner
2	Data minimisation by role	Implemented. Each role sees only what its function requires	None
3	Record of access to personal data	Partly implemented through the clinical access log	Tamper resistance and a distinct export event, see SEC-04 and SEC-05
4	Retention and disposal	Not set. No period is assumed by the system	Policy required. The system does not invent one
5	Security of processing	Partly implemented	Transport encryption and backups, see SEC-01 and SEC-11
6	Data residency	Deployed only on KMC controlled infrastructure	To be confirmed as an approved position

4.2 Synthetic data in non-production

No real clinical record is copied into a development, testing or demonstration environment at any point. This is stated as an absolute because it is the control most often eroded by convenience, and because a copy of clinical data taken for testing is a disclosure whatever the intention behind it.

4.3 Patient history export and data minimisation

The Data Protection and Privacy Act, 2019 requires personal data processed for a purpose to be adequate and relevant, and not excessive. Opening the patient record currently creates one detail event. The browser then generates the history summary from the data already returned, so downloading the file creates no further server request and no distinct access event. The access_route constraint does not permit export.

A portable clinical file can be disclosed beyond the application and is a materially different processing act from viewing the screen. An export event containing the document type and patient reference would be relevant to accountability, while clinical narrative in that event would be excessive and would turn the audit log into another clinical record. The current log is therefore not adequate to distinguish viewing from export, and the narrow event proposed at DEC-037 is the proportionate correction.

4.4 A conflict requiring a decision

The referral form requires the Head of Division and the Chief of Staff to sign a document that carries a provisional diagnosis, HIV status and mental health condition. That cannot stand alongside the rule that no management role sees an individual clinical record.

The clinical service can assemble a minimum-disclosure summary containing the patient, destination, referral reason and cost implication, but its route is officer-only. No management role has any route to that summary or to the referral while DEC-024 remains open. If KMC decides that authorisers see clinical content, the Corporation must record the lawful basis, exact fields, controls and retention before the route is changed, because digitising the form does not itself authorise the disclosure.

5 Remediation

5.1 Before user testing

User testing uses synthetic data only, so the bar is lower than for production. The following must nonetheless be closed, because testing takes place on a KMC network with real accounts held by real people.

Table 5.1: Remediation required before user testing

S/N	Reference	Action	Owner
1	SEC-01	Terminate transport encryption at the ingress and set the secure cookie flag	KMC ICT
2	SEC-02	Replace every development credential with a value generated from a controlled source	KMC ICT
3	SEC-13	Restrict the identity provider administrative console to an administrative network	KMC ICT
4	None	Confirm in writing that the environment holds synthetic data only, and that participants are named	Health and Wellness Division

5.2 Before real clinical records

Table 5.2: Remediation required before any real clinical record

S/N	Reference	Action	Owner
1	SEC-03	Enable multi factor authentication for the officer and manager roles	KMC ICT
2	SEC-04	Create the audit boundary, enforce insert-only database grants and place the access log beyond clinical service alteration	KMC ICT and development
3	SEC-05	Write a distinct export event before generating a patient history summary and refuse generation if the write fails	Development and data protection owner
4	SEC-06	Replace the shared metrics ingest secret with a scoped Keycloak service account	KMC ICT
5	SEC-10	Build appended amendment of a signed clinical record	Development
6	SEC-12	Complete clinical PostgreSQL TLS configuration or approve a different connection policy in writing	KMC ICT
7	SEC-14	Configure nightly encrypted backup with a separate clinical key, and test a restore	KMC ICT
8	None	Establish lawful basis, privacy notice and retention policy	Data protection owner
9	None	Settle the referral authorisation conflict described in Section 4.3	Division and data protection owner

S/N	Reference	Action	Owner
10	None	Appoint named business, technical and data owners	Department and ICT

5.3 Compensating controls during testing

Until the remediation in Section 5.2 is complete, the following compensating controls are proposed for the duration of user testing and should be formally adopted.

- The environment holds synthetic records only, and this is verified before each testing session rather than assumed.
- Access is restricted to named participants, and accounts are disabled at the end of testing.
- The environment is reachable only from the plant network.
- Any defect that exposes a record across roles halts testing until it is closed.

6 Conclusion

The confidentiality boundary is present in identity, routes, services and deployment. Delegated authentication, tokens held away from the browser, route-wide access tests, server-side referral identity derivation, route-template logging, a separately credentialed clinical database and the narrow metrics contract are implemented controls. They reduce the likelihood that a general service defect becomes a clinical disclosure.

The review does not conclude that the audit position is complete. The clinical service can alter its own access-log table, a patient history export is indistinguishable from viewing, and no separate audit deployable exists. Clinical to metrics authentication also remains a shared secret, DEC-024 leaves management referral authorisation without a route, and the k3s clinical database cannot satisfy its required TLS connection as configured. These are application and deployment weaknesses, not matters that can be represented as future hardening.

The system may proceed to user testing with synthetic data only after the controls in Section 5.1 are completed and evidenced. No real clinical record may be entered until Section 5.2 is complete, DEC-024 and DEC-037 are resolved for the intended workflows, and the named data protection and service owners accept the remaining position.

Table 6.1: Information security review sign-off

Role	Name	Signature	Date
Prepared by, Software Engineering Intern			
Reviewed by, KMC ICT			
Compensating controls accepted by, Data Protection Owner			
Approved by, Head of Department, Quality, Health, Safety and Environment			